

S5 · Auth mínima

title: "S5 · Auth mínima" status: "approved" version: "1.0" priority: "alta"
dependencies: ["S1"]

Como usuario, **quiero** entrar con email + password y recibir un JWT válido en ambos backends,
para operar sin bypass.

Objetivo: login compatible + guards JWT en todos los endpoints; muere X-User - Id.

Endpoint (app/routers/auth.py)

Método	Path	Body	Respuesta
POST	/api/auth/login	{email, password}	{token, user:{id, display_name, role, email, estado_actual, can_view_dashboard}}

Token: HS256, iss=SoporteTecnico, aud=SoporteTecnicoApp, claims
NameIdentifier/Name/Role/Email/sub, expira 365 días, firma con JWT_SECRET del env.

Reglas

- **RN-S5-01:** email se normaliza (trim + lower) y busca case-insensitive (como ILike).
- **RN-S5-02:** 401 exactos: "Correo no registrado" · "Este usuario no tiene contraseña asignada. Contacta al administrador." · "Contraseña incorrecta".
- **RN-S5-03:** require_user exige Authorization: Bearer; decodifica, valida firma/iss/aud/expiration y carga el usuario de DB (401 si no existe).
- **RN-S5-04:** ningún endpoint acepta ya X-User - Id; routers S2-S4 sin cambios de lógica.
- **RN-S5-05:** bcrypt checkpw contra PasswordHash \$2b\$ (compatible .NET).

Catálogo de errores

Código	Condición	HTTP
ERR-S5-01	credenciales malas / sin password	401 + mensaje
RN-S5-02	sin Bearer / token inválido / expirado / user inexistente	401
ERR-S5-03	body malformado	422 estándar

Archivos

backend-fastapi/app/services/tokens.py	# crear/validar JWT
(puros, testeables sin DB)	
backend-fastapi/app/routers/auth.py	# POST login
backend-fastapi/app/core/security.py	# require_user · Bearer
(modifica)	
backend-fastapi/tests/test_auth.py	# login ok/ko, claims,
expiración, guards	
backend-fastapi/tests/*.py	# migran de X-User-Id a
login (modifica)	

Criterios de aceptación

- Login Mattias/Soporte2026* · 200 con token; payload trae iss/aud/claims/exp·365d.
- Login mal · 401 con cada mensaje según caso.
- Endpoints S2·S4: sin token · 401; con token · 200 (mismos tests, nueva auth).
- Token firmado con otra key · 401.

Definition of Done

- 1 [] login + guards verificados contra postgres-dev real
- 2 [] suite completa verde con Bearer (cero X-User-Id restante)
- 3 [] ruff + basedpyright limpios
- 4 [] Sin cambios fuera de backend-fastapi/

Fuera de alcance

- Códigos por mail, registro, recovery · · refresh tokens (el JWT dura 365d como .NET).